	Politechnika Bydgoska im. J. J. Śniadeckich Wydział Telekomunikacji, Informatyki i Elektrotechniki	
Przedmiot	Metody ochrony cyberprzestrzeni - Projekt	
Prowadzący	dr hab. inż. prof. PBŚ Michał Choraś	
Temat	Atak XSS - sprawozdanie	
Student	Adam Szreiber (121515)	
Email	adaszr000@pbs.edu.pl	

Atak XSS (Cross-Site Scripting) to technika ataku, która polega na wstrzykiwaniu złośliwego kodu JavaScript lub innego rodzaju skryptu do strony internetowej, który jest później wykonywany przez przeglądarkę użytkownika. Atak XSS może wystąpić, gdy strona internetowa nie jest dostatecznie filtrowana lub walidacja danych wejściowych przed umieszczeniem ich na stronie, co pozwala potencjalnie złośliwym użytkownikom wstrzyknąć kod, który zostanie później wykonany w przeglądarce innych użytkowników odwiedzających tę stronę.

Istnieje kilka rodzajów ataków XSS:

Stored XSS (Trwały XSS): Złośliwy kod jest trwale przechowywany na serwerze i dostarczany do przeglądarki użytkowników podczas odwiedzania konkretnej strony.

Reflected XSS (Odbity XSS): Złośliwy kod jest wstrzykiwany jednorazowo i jest przesyłany do serwera wraz z zapytaniem HTTP. Następnie serwer odsyła złośliwy kod w odpowiedzi, który jest wykonywany przez przeglądarkę klienta.

DOM-based XSS (XSS związanego z modelem obiektu dokumentu): W tym przypadku atak odbywa się na poziomie przeglądarki, a złośliwy kod modyfikuje DOM (Model Obiektu Dokumentu), co może prowadzić do niebezpiecznych efektów.

Atak XSS może prowadzić do różnych konsekwencji, takich jak kradzież sesji użytkownika, przechwytywanie danych osobistych, zmiana zawartości strony, przekierowywanie użytkowników na inne złośliwe strony, czy nawet ataki na inne aplikacje w sieci wewnętrznej.

1. DOM-based XSS

DOM-based XSS (Cross-Site Scripting związane z modelem obiektu dokumentu) to specyficzny rodzaj ataku XSS, który skupia się na manipulacji DOM (Document Object Model) w przeglądarce internetowej. W przeciwieństwie do tradycyjnych form XSS, w przypadku DOM-based XSS atak skupia się na zmianie struktury DOM bez konieczności ingerencji w treść strony na serwerze.

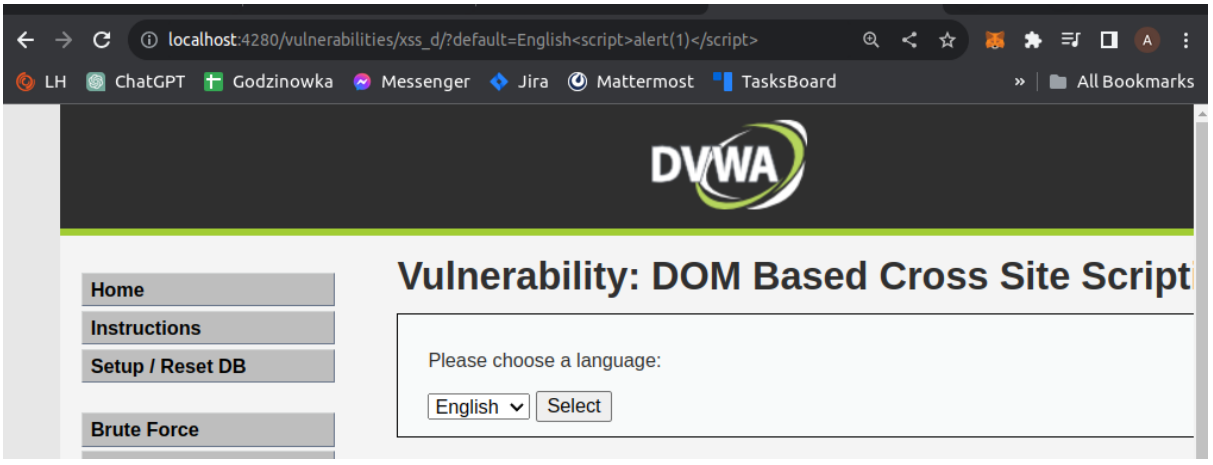
Oto, jak przebiega atak DOM-based XSS:

Wstrzyknięcie złośliwego kodu: Atak zaczyna się od wstrzyknięcia złośliwego kodu do danych wejściowych obsługiwanych przez klienta, takich jak parametry adresu URL, dane formularza, czy fragmenty skryptów JavaScript. Ten złośliwy kod jest później wykonywany przez przeglądarkę.

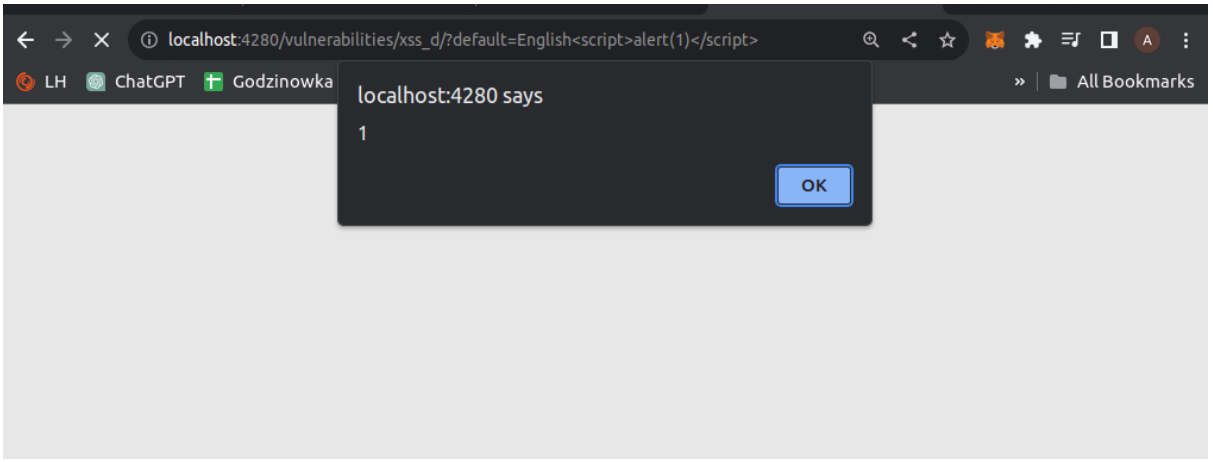
Przetworzenie przez przeglądarkę: Po dostarczeniu strony internetowej do przeglądarki, kod JavaScript jest wykonywany, a strona tworzy lub modyfikuje DOM w zależności od dostarczonych danych wejściowych.

Wykorzystanie złośliwego kodu: Złośliwy kod, który został wstrzyknięty i wykonany, może manipulować DOM-em, zmieniać zawartość strony, modyfikować formularze, przekierowywać użytkowników na inne strony lub wykonywać inne złośliwe działania.

Przykładowo, załóżmy, że strona internetowa zawiera skrypt JavaScript, który pobiera dane z parametru adresu URL i wstawia je bez żadnej walidacji do treści strony. Jeśli atakujący wstrzyknie złośliwy kod poprzez parametry adresu URL, a strona użyje tego kodu do bezpośredniej modyfikacji DOM, to mamy do czynienia z atakiem DOM-based XSS.



Ryc 1. Należy zwrócić uwagę na link który zawiera w sobie niebezpieczny kod w postaci <script>



Ryc 2. Uruchomienie wadliwego linku spowoduje wykonanie skryptu z pasku wyszukiwania

2. XSS reflected

Atak XSS Reflected (Odbity XSS) występuje, gdy złośliwy kod jest wstrzykiwany do strony internetowej i odbijany z powrotem do przeglądarki użytkownika w odpowiedzi serwera. Jest to jedna z najczęstszych form ataków XSS. Oto bardziej szczegółowy opis tego rodzaju ataku:

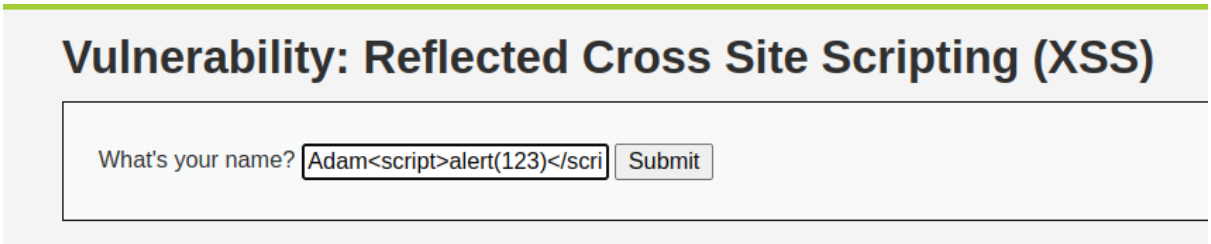
Wstrzyknięcie złośliwego kodu: Atak zaczyna się od momentu, gdy atakujący wstrzykuje złośliwy kod do pewnych danych wejściowych obsługiwanych przez serwer. Te dane mogą obejmować parametry adresu URL, pola formularza, czy nawet nagłówki żądań HTTP.

Przesłanie danych do serwera: Serwer przetwarza otrzymane dane, w tym złośliwy kod, i umieszcza je w treści strony lub w innych miejscach, które są później dostarczane do przeglądarki klienta.

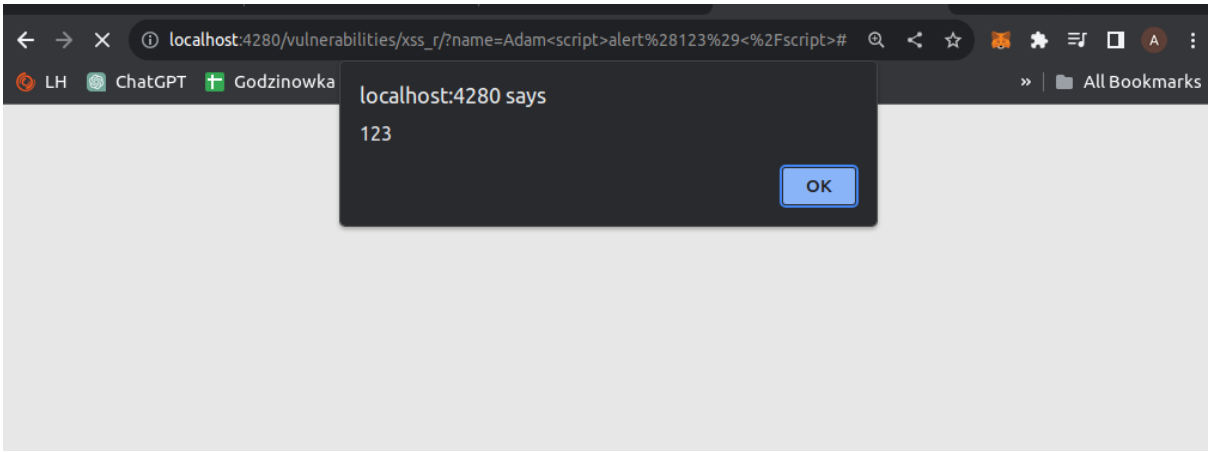
Odbicie złośliwego kodu: Zamiast trwale przechowywać wstrzyknięty złośliwy kod na serwerze (jak w przypadku Stored XSS), serwer zwraca złośliwy kod w odpowiedzi na żądanie HTTP wysłane przez przeglądarkę użytkownika. To odbicie złośliwego kodu powoduje, że przeglądarka wykonuje go w kontekście strony internetowej.

Wykonanie złośliwego kodu: Gdy przeglądarka odbiera odpowiedź serwera zawierającą złośliwy kod, wykonuje go, co może prowadzić do różnych konsekwencji, takich jak kradzież danych sesji, przechwycenie informacji o użytkowniku, manipulacja treści strony czy przekierowanie na inne złośliwe strony.

Przykładem może być atak, w którym atakujący umieszcza złośliwy skrypt w parametrze adresu URL, a następnie przekonuje ofiarę do kliknięcia w link zawierający ten parametr. Serwer, przyjmując żądanie z parametrem, odbija złośliwy kod z powrotem do przeglądarki ofiary, co prowadzi do wykonania skryptu w kontekście strony.



Ryc 3. Wstrzyknięcie skryptu do elementu input



Ryc 4. Zatwierdzenie przyciskiem “submit” spowoduje wykonanie kodu skryptu.

3. XSS stored

Atak XSS Stored (Trwały XSS) to rodzaj ataku, w którym złośliwy kod jest trwale przechowywany na serwerze i dostarczany do przeglądarek użytkowników podczas odwiedzania konkretnej strony. Poniżej znajdziesz bardziej szczegółowy opis tego rodzaju ataku:

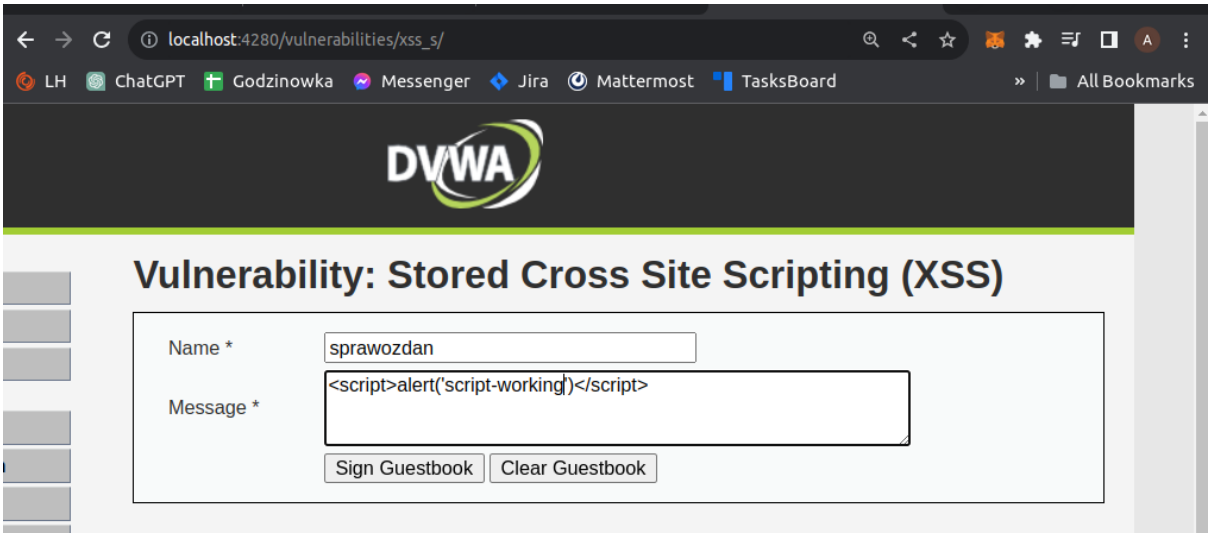
Wstrzyknięcie złośliwego kodu: Atak zaczyna się od wstrzyknięcia złośliwego kodu do danych wejściowych obsługiwanych przez serwer. Te dane mogą obejmować pola formularza, komentarze, czy inne obszary, w których użytkownicy mogą wprowadzać treść.

Przechowywanie na serwerze: Złośliwy kod, raz wstrzyknięty, zostaje trwale zapisany na serwerze. Może to nastąpić, na przykład, poprzez zapisanie go w bazie danych lub pliku.

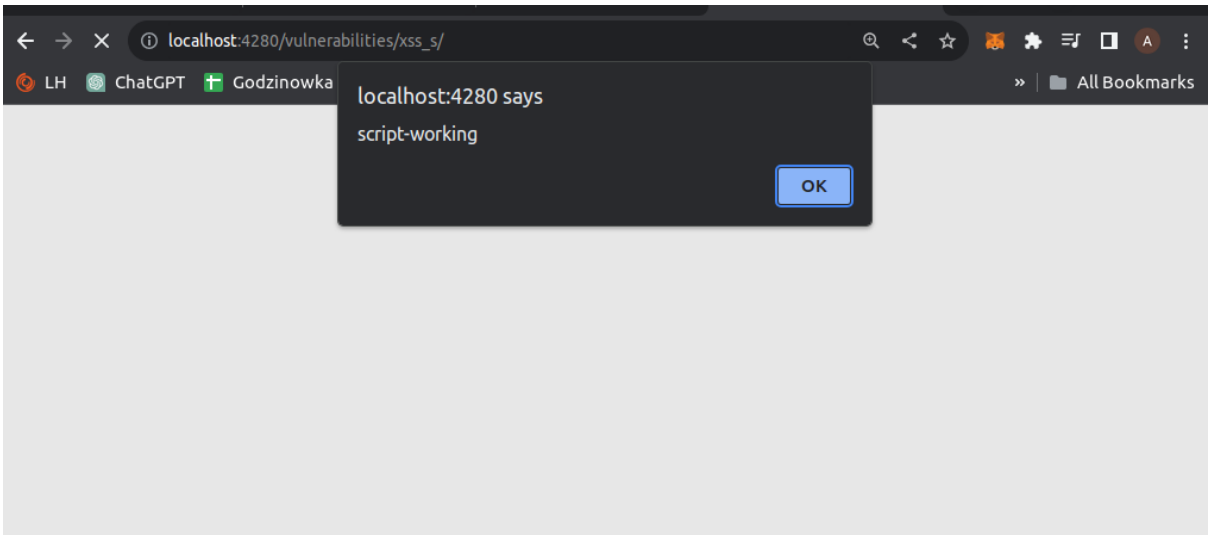
Dostarczanie do przeglądarek użytkowników: Kiedy użytkownik odwiedza stronę, na której znajduje się złośliwy kod (na przykład, czytając zapisane komentarze), serwer dostarcza ten kod wraz z treścią strony.

Wykonanie złośliwego kodu: Przeglądarka wykonuje złośliwy kod w kontekście strony internetowej, co może prowadzić do różnych skutków, takich jak kradzież danych sesji, przechwycenie informacji o użytkowniku, manipulacja treści strony, czy przekierowanie na inne złośliwe strony.

Przykładem może być sytuacja, w której atakujący umieszcza złośliwy skrypt w polu komentarza na stronie internetowej. Gdy inny użytkownik odwiedza tę stronę i przegląda komentarze, serwer dostarcza złośliwy kod wraz z treścią komentarza. W efekcie przeglądarka wykonuje ten kod w kontekście strony, narażając użytkownika na ryzyko ataku.



Ryc 5. Dodanie wadliwego kodu w miejsce “Message”, następnie zatwierdzenie formularza spowoduje zapisanie tych danych do bazy danych



Ryc 6. Wejście na stronę z wadliwą treścią (stworzoną na ryc 5) spowoduje wykonanie skryptu - za każdym razem gdy otworzymy daną stronę

4. Wnioski

Podczas laboratorium, eksperymentując z różnymi rodzajami ataków XSS, zdobyłem głębsze zrozumienie zagrożeń z nimi związanych. W praktyce zaprezentowano Reflected XSS, Stored XSS i DOM-based XSS, ukazując bezpośrednie skutki takich ataków, takie jak możliwość kradzieży sesji, manipulacji treścią strony czy przekierowywania użytkowników na złośliwe strony. Doświadczenia te podkreśliły kluczową rolę właściwej walidacji i filtrowania danych wejściowych w kontekście różnych poziomów aplikacji.